



第二章 密码基础

目 录

「01」

知识点一：基本概念

「02」

知识点二：对称密码

「03」

知识点三：公钥密码

1. 算法复杂度

算法复杂度包括时间复杂度和空间复杂度，分别由运行此算法所需要的计算时间 T 或者计算空间 S 来表示，这两个值往往表示为算法输入规模 λ 的函数。在分析并确定一个算法复杂度时，通常用大 O 符号 $O(\cdot)$ 来表示。

在算法分析的应用中，通常采用时间复杂度来描述算法复杂度。从时间复杂度的角度来看，算法一般可分为三类：多项式时间算法、亚指数时间算法和指数时间算法，算法时间复杂度依次增高。

- 多项式时间算法：假设 n 表示一个算法输入量的规模， k 为某个常数，执行该算法的时间复杂度为 $O(n^k)$ ，称该算法为一个多项式时间算法。

在计算复杂度理论中，多项式时间算法被看成是一个简单的算法。如果解决一个问题的算法是多项式时间的，则该问题不是一个计算困难问题。

1. 算法复杂度

- 指数时间算法：指数时间算法是指该算法的时间复杂度为 $O(t^{f(n)})$ 这里 t 是一个大于 1 的常数， $f(n)$ 是关于算法输入规模 n 的一个多项式函数。

在计算复杂度理论中，指数时间算法具有过高的时间算法复杂度，所以该算法不是一个有效算法。对于一个计算问题来说，如果解决该问题的算法是指数时间算法，则该问题是一个计算困难问题。

- 亚指数时间算法：亚指数时间算法是指该算法的时间复杂度为 $O(t^{f(n)})$ 这里 t 是一个大于 1 的常数， $f(n)$ 是大于常数小于 n 的线性多项式的一个函数。

亚指数时间算法的复杂度介于多项式时间算法和指数时间算法之间。

2. P问题和NP问题

P是Polynomial-time，即多项式时间；NP是指Non-deterministic Polynomial-time，即非确定性多项式时间。

- P问题：用确定性算法可以在多项式时间内求解的问题。

例如：冒泡排序、快速排序等问题。

- NP问题：用非确定算法可以在多项式时间内求解的问题。

非确定性算法一解决方式是随机的，非确定的，意味着问题求解是很难的

P类问题是易解问题，NP类问题是难解问题。

2. P问题和NP问题

举例：

□ NP问题：将非常多的不规则碎片拼成一个完整的杯子，解决方式是随机的，且解决起来非常困难，是一个NP问题；

□ P问题：数杯子碎片有多少个，这种问题是比较容易解决的，是P问题。

○ NP问题不一定在多项式时间内可解，但可以在多项式时间内验证

比如上面的碎片拼杯子的问题，虽然求解过程可能算法很复杂，但是结果是一个完整的杯子，很容易验证是由给定的碎片拼成的。

一个算法的时间复杂度是 $O(n^3)$ ，则该算法是

- ☐ A 多项式时间算法
- ☐ B 指数时间算法
- ☐ C 亚指数时间算法
- ☐ D 都不是

目 录

「01」

知识点一：基本概念

「02」

知识点二：对称密码

「03」

知识点三：公钥密码

1.对称密码体制

- 对称密钥密码体制基本特征是发送方和接收方共享相同的密钥，即加密密钥与解密密钥相同。
- 对称密码的优点在于加解密处理速度快。

2. 对称密码分类

- ❑ 对称密钥体制，根据对明文的加密方式的不同而分为两类：分组密码（Block cipher）和序列密码（Stream cipher）。
- ❑ 分组密码，也被称为分块密码，是将明文消息编码表示后的位（Bit）或字符序列，按指定的分组长度划分成多个分组（Block）后，每个分组分别在密钥的控制下变换成等长的输出。常见的分组密码算法主要有DES、IDEA、AES等。
- ❑ 序列密码，也被称为流密码，是将明文和密钥都划分为位或字符的序列，并且对明文序列中的每一位或字符都用密钥序列中的对应分量来加密。公开的序列密码算法主要有RC4、SEAL等。
- ❑ 分组密码每一次加密一个明文分组，而序列密码每一次加密一位或者一个字符，两种密码在计算机系统中都有广泛的应用。

3. 基本设计思想

混淆（confusion）与扩散（diffusion）是设计对称密码的主要方法，最早出现在香农1945年的论文《密码学的数学理论》中。

① 混淆（Confusion）：是一种使密钥与密文之间的关系尽可能模糊的加密操作。如今实现混淆常用的一个元素就是替换；这个元素在AES和DES中都有使用。

② 扩散（Diffusion）：是一种为了隐藏明文的统计特性而将一个明文符号的影响扩散到多个密文符号的加密操作。最简单的扩散元素就是位置换，它常用于DES中；而AES则使用更高级的Mixcolumn操作。

■ 仅执行扩散不够安全，但是将扩散操作串联起来就可以建立一个更强壮的密码。将若干加密操作串联起来的思想也是Shannon提出的，这样的密码也叫乘积密码（Product cipher）。乘积密码就是以某种方式连续执行两个或多个密码，以使得所得到的最后结果或乘积从密码编码的角度比其任意一个组成密码都更强。

3. 基本设计思想

目前，所有的分组密码都是乘积密码，因为它们都是由对数据重复操作的轮组成的，其中每轮都执行一次扩散和混淆操作，如下图所示：



4. 分组密码工作模式

- ❑ 即使有了安全的分组密码算法，也需要采用适当的工作模式来隐蔽明文的统计特性、数据的格式等，以提高整体的安全性，降低删除、重放、插入和伪造成功的机会。
- ❑ 分组密码的工作模式是一个算法，它刻画了如何利用分组密码提供信息安全服务。主要有五种工作模式，它们分别是
 - ❑ 电子密码本ECB (Electronic Codebook Mode) 模式、
 - ❑ 密码分组链CBC (Cipher Block Chaining Mode) 模式、
 - ❑ 密码反馈CFB (Cipher Feedback Mode) 模式、
 - ❑ 输出反馈OFB (Output Feedback Mode) 模式、
 - ❑ 计数CTR (Counter Mode) 模式。

4. 分组密码工作模式

□ 电子密码本模式

直接利用分组密码对明文的各分组进行加密。设明文 $M=(M_1, M_2, \dots, M_n)$ ，相应的密文 $C=(C_1, C_2, \dots, C_n)$ ，其中：

$$C_i = E_k(M_i), \quad i=1, 2, \dots, n$$

电子密码本是分组密码的基本工作模式。

ECB的一个缺点是容易暴露明文的数据模式。

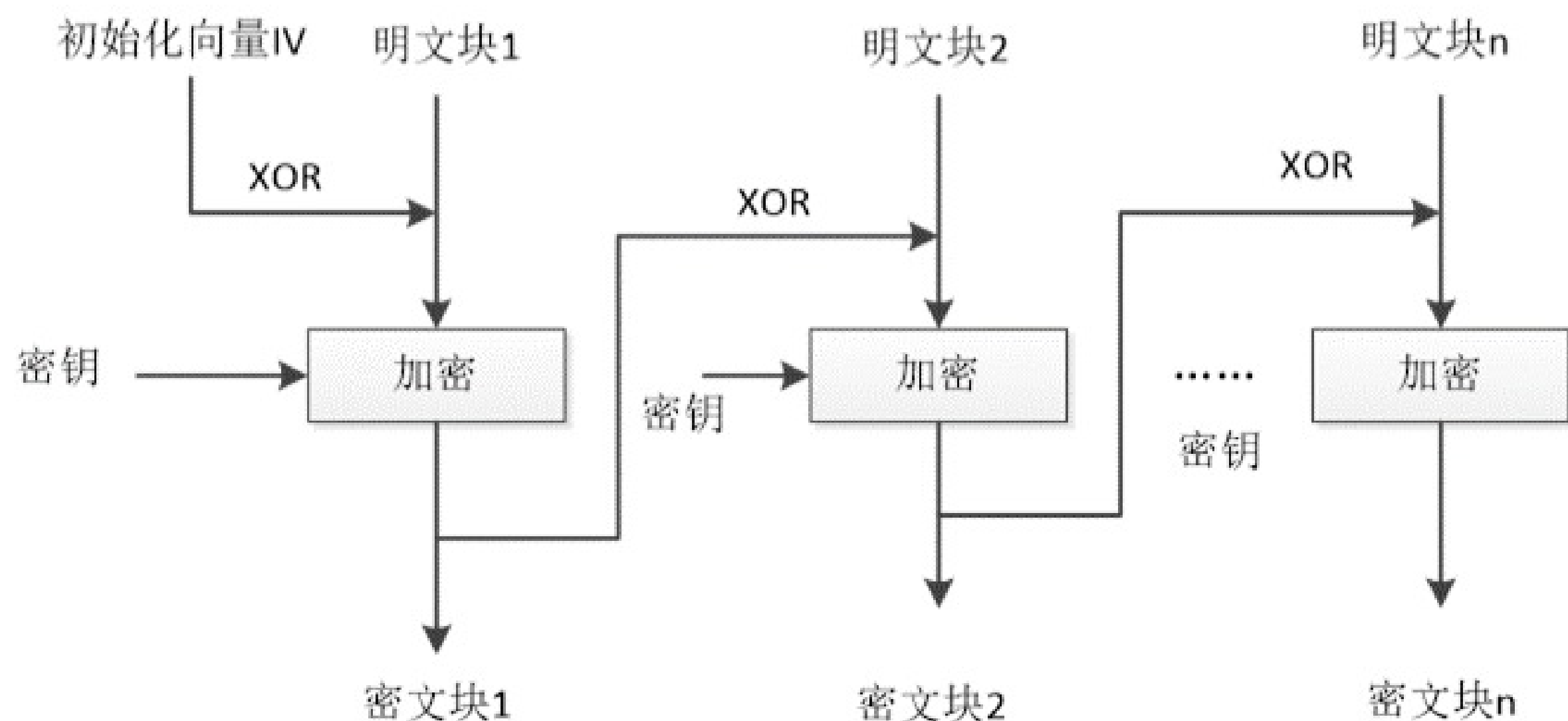
ECB容易遭受重放攻击。攻击者通过重放，可以在不知道密钥情况下修改被加密过的消息，用这种方法欺骗接收者。例如在实际应用中，不同的消息可能会有一些比特序列是相同的（消息头），攻击者重放消息头，修改消息体以欺骗接收者。

4. 分组密码工作模式

□ 密码分组链模式

明文要与前面的密文进行异或运算然后被加密，从而形成密文链。

密码分组链模式的运行原理如图所示。每一分组的加密都依赖于所有前面的分组。在处理第一个明文分组时，与一个初始向量（IV，Initialization Vector）组进行异或运算。IV不需要保密，它可以明文形式与密文一起传送。



□ 使用 IV 后，完全相同的明文被加密成不同的密文。敌手再用分组重放进行攻击是完全不可能的了。

□ CBC 模式除了用于加密大长度明文外，还常用于报文鉴别与认证。

有关对称密码，下列说法错误的是

- A 通过设置初始向量IV和采用密码分组链模式，可以抵御重放攻击
- B 混淆的目的是为了隐藏明文的统计特性
- C 分组密码每一次加密一个明文分组
- D 对称密钥密码体制中，发送方和接收方共享相同的密钥

目 录

「01」

知识点一：基本概念

「02」

知识点二：对称密码

「03」

知识点三：公钥密码

1. 基本概念

- ❑ 对称加密最大的缺点在于其密钥管理困难，因为通信的双方必须首先预约相同的密钥后才能进行加密，而且在网络环境下，为了安全，密钥应当经常更换，在用户越多的情况下，密钥的数量及管理难度相应增加。1976年，Diffie和Hellman第一次提出了公开密钥密码的概念，开创了一个密码新时代。
- ❑ 公开密钥密码，也就是非对称密码体制，基本思想是将对称密码的密钥 k 一份为二，分为加密密钥 K_e 和解密密钥 K_d ，用加密密钥 K_e 控制加密，用解密密钥 K_d 控制解密，而且由计算复杂性确保由加密密钥 K_e 在计算上不能推出解密密钥 K_d 。这样，即使是将 K_e 公开也不会暴露 K_d ，也不会损害密码的安全。于是便可将 K_e 公开，而只对 K_d 保密。由于 K_e 是公开的，只有 K_d 是保密的，所以便从根本上克服了传统密码在密钥分配上的困难。

1. 基本概念

(1) 加解密过程

公开密钥密钥体制中，一个用户有两个密钥，即公钥 K_e 和私钥 K_d ，加解密的过程如下：

①如果要给一个拥有公钥 K_e 的用户发送信息 m ，则可以用其公钥 K_e 执行加密算法 E ，以加密明文 m 得到密文 c ： $c=E_{K_e}(m)$ 。

②用户收到密文之后，用自己的私钥 K_d 执行解密算法 D 以恢复明文 m ：

$$m = D_{K_d}(c)。$$

可见，加密算法 E 和解密算法 D 是可逆运算，即： $D(E(m))=m$ ，不过加解密过程使用的密钥不同，不同于对称加密无论是加密还是解密均使用相同的密钥。

注意： $E_{K_e}(m)$ 也可以表达为 $E(m, K_e)$ 。

1. 基本概念

(2) 数字签名的应用

在非对称密码中，还有一个重要的特性，也就是**加密和解密运算具有可交换性**，即：

$$D(E(m)) = E(D(m))$$

这个特性使得非对称密码可应用到数字签名中。一个拥有公钥 K_e 和私钥 K_d 的用户，实现数字签名的过程如下：

- ① 拥有公钥 K_e 的可以用其**私钥** K_d 执行解密算法 D ，以产生信息 m 的签名信息 sig ： $sig = D_{K_d}(m)$ 。
- ② 要验证一个签名信息 sig 是否某用户的签名时，只需要用该用户的公钥 K_e 执行如下校验过程计算出校验值 m' ： $m' = E_{K_e}(c)$ ，如果 $m' = m$ ，那么验证成功，否则失败。

1. 基本概念

(3) 优缺点

- ❑ 公开密钥密码的优点在于从根本上克服了对称密码密钥分配上的困难，且易于实现数字签名。
- ❑ 由于公开密钥密码通常依赖于某个难解的问题设计，虽然安全性高，但降低了加解密效率，是公开密钥密码一大缺点。
- ❑ 在应用中，通常采用对称密码体制实现数据加密、公钥密码体制实现密钥管理的混合加密机制。公钥密码主要用于身份认证、密钥协商，一种混合机制是通过公钥密码进行密钥协商后得到一个对称密码体制的会话密钥，进而用作加密。

1. 基本概念

(4) 安全性

在安全性方面，非对称密码通常依赖于某个难解的数学难题。也就是说，基于难解问题设计密码是非对称密码设计的主要思想。

- **NP问题**不一定在多项式时间内可解，但可以在多项式时间内验证。比如：大数分解问题，给定一个极大数，让你拆成两个素数相乘，可能很久都解不出来，也就是在多项式时间复杂度内不可以解决。但是，我告诉你这是 $p*q$ 得到的，那么很简单就能在多项式时间内验证是否正确，这就是NP问题。
- 公开密钥密码，开拓了直接利用**NP问题**设计密码的技术路线。

1. 基本概念

(4) 安全性

○ NP问题在密码学中的应用

对于一个NP问题，若能找到一个计算序列用于设计加解密算法，那么密码分析者在不知道计算序列的情形下求解问题成为计算上不可能的。也就是说，NP问题在密码学中的价值便是这些NP问题没有已知的算法可以在多项式时间内解决，作为攻击者可能需要指数级或者更高的破译时间。

1. 基本概念

(4) 安全性

- 典型且流行的非对称密码包括RSA、ElGamal、椭圆曲线密码（ECC, Elliptic Curves Cryptography）等。RSA基于大整数因式分解难的问题设计；ElGamal 基于离散对数求解困难的问题设计；而ECC基于椭圆曲线离散对数求解困难的问题设计。
- 自2000年起，基于双线性对的基于身份加密（IBE）、基于属性加密（ABE）等，还有基于格的公钥密码体制逐渐兴起，并且在减少密钥管理复杂度、细粒度访问控制、抗量子攻击密码体制设计等起到了重要作用。

2. RSA算法

1978年，美国麻省理工学院的三名密码学者Rivest、Shamir和Adleman提出了一种基于大整数因数分解困难性的公开密钥密码，简称为RSA密码。

(1) 大整数因数分解问题

大整数因数分解问题是指：将两个大素数相乘十分容易，但想要对其乘积进行因数分解却极其困难，因此可以将乘积公开作为加密密钥。

2. RSA算法

(2) 算法描述

- ①随机选择两个大素数 p 和 q ， p 和 q 都保密；
- ②计算 $n=pq$ ，将 n 公开；
- ③计算 $\varphi(n)=(p-1)(q-1)$ ， $\varphi(n)$ 保密；
- ④随机选取正整数 e ， $1 < e < \varphi(n)$ 且 e 与 $\varphi(n)$ 互素，将 e 公开； e 和 n 就构成用户公钥；
- ⑤根据 $ed \equiv 1 \pmod{\varphi(n)}$ （ $\equiv$ 表示模同余运算），计算出 d ， d 保密； d 和 n 构成用户私钥；
- ⑥加密运算： $C = M^e \pmod{n}$ ；
- ⑦解密运算： $M = C^d \pmod{n}$ 。

$\varphi(n)$ 是称为欧拉函数，表示在比 n 小的正整数中与 n 互素的数的个数。若 p 和 q 是素数，且 $n=pq$ ，则 $\varphi(n)=(p-1)(q-1)$ 。例如， $6=2*3, \varphi(6)=2$ 。

由以上算法可见，RSA密码的公开加密密钥 $K_e = \langle n, e \rangle$ ，而保密的解密密钥 $K_d = \langle p, q, d, \varphi(n) \rangle$ 。

2. RSA算法

正确性：给定密文 $C = M^e \bmod n$ ，可以利用私钥 $K_d = \langle p, q, d, \varphi(n) \rangle$ 解密，即

$$(C)^d = (M^e)^d = M^{ed} = M \bmod n$$

加密和解密运算具有可交换性：

$$D(E(m)) = (M^e)^d = M^{ed} = (M^d)^e = E(D(m)) \bmod n$$

通过该可交换性看出，如果执行解密算法产生的签名，也可以通过公钥来进行验证。

2. RSA算法

(2) 安全性

密码分析者攻击RSA密码的一种可能的途径是截获密文 C ，从中求出明文 M 。他们知道：

$$M=C^d \bmod n$$

因为 n 是公开的，要从 C 中求出明文 M ，必须先求出 d ，而 d 是保密的。但他们知道， e 是公开的，要从中求出 d ，必须先求出 $\varphi(n)$ ，而 $\varphi(n)$ 是保密的。但他们知道：

$$n=pq$$

要从 n 求出 p 和 q ，只有对 n 进行因式分解。

2. RSA算法

(2) 安全性

由此可见，只要能对 n 进行因式分解，便可攻破**RSA**算法。虽然大合数因式分解是十分困难的，但是随着科学技术的发展，人们对于大合数因式分解的能力在不断的提高。1994年，成功分解了129位的大合数；1996年又破译了RSA-130；1999年又破译了RSA-140。现在，科学家们正向更高位数的**RSA**发起冲击。

因此，要应用**RSA**密码，应当采用足够大的整数 n 。

普遍认为， n 至少应取1024位，最好是2048位。只要合理的选择参数，正确的使用，**RSA**就是安全的。

3. ElGamal算法

ElGamal密码建立在离散对数的困难性之上，Diffie-Hellman密钥分配协议和美国数字签名标准算法DSA等也都是建立在离散对数问题之上的。

(1) 离散对数问题

设 p 为素数，若存在一个正整数 g ，使得 $g, g^2, g^3, \dots, g^{p-1}$ ，关于模 p 互不同余，则称为模 p 的本原元。显而易见若 g 为模 p 的本原元，则对于 $i \in \{1, 2, 3, \dots, p-1\}$ 一定存在一个正整数 k ，使得 $i \equiv g^k \pmod{p}$ 。

设 p 为素数， g 为模 p 的本原元， g 的幂乘运算为

$$Y \equiv g^X \pmod{p}, 1 \leq X \leq p-1$$

其中， X 是以 g 为底的模 p 的对数，即求解对数 X 的运算为

$$X \equiv \log_g Y, 1 \leq X \leq p-1$$

由于上述运算是定义在模 p 有限域上的，所以称为离散对数运算。

3. ElGamal算法

从 X 计算 Y 是容易的:

$$Y \equiv g^X \bmod p, 1 \leq X \leq p-1$$

可是从 Y 计算 X 就困难的多:

$$X \equiv \log_g Y, 1 \leq X \leq p-1$$

- 利用目前最好的算法, 对于小心选择的 p 将至少需用 $p^{1/2}$ 次以上的运算, 只要 p 足够大, 求解离散对数问题是相当困难的。
- 这便是著名的离散对数问题。
- 可见, 离散对数问题具有较好的单向性。

3. ElGamal算法

(2) ElGamal密码

随机选择一个大素数 p ，且要求 $p-1$ 有大素数因子。再选择一个模 p 的本原元 g ，将 p 和 g 公开。

□ 密钥生成：用户随机的选择一个整数 d 作为自己的私钥， $1 \leq d \leq p-2$ ，计算 $y \equiv g^d \pmod{p}$ ，取 y 为自己的公钥。

□ 加密：将明文消息 M ($0 \leq M \leq p-1$)加密成密文的过程如下：

① 随机选择一个整数 r ， $1 \leq r \leq p-2$ 。

② 计算 $U = y^r \pmod{p}$ $C_1 = g^r \pmod{p}$ $C_2 = UM \pmod{p}$

③ 取 (C_1, C_2) 作为密文

□ 解密：将密文 (C_1, C_2) 解密的过程如

① 计算 $V = C_1^d \pmod{p}$

② 计算 $M = C_2 V^{-1} \pmod{p}$ —————

$$\begin{aligned} C_2 V^{-1} \pmod{p} &= (UM) V^{-1} \pmod{p} \\ &= (UM) (C_1^d)^{-1} \pmod{p} \\ &= (UM) (g^r)^d^{-1} \pmod{p} \\ &= (UM) (g^d)^r^{-1} \pmod{p} \\ &= (UM) (y)^r^{-1} \pmod{p} \\ &= (UM) (U)^{-1} \pmod{p} \\ &= M \pmod{p} \end{aligned}$$

3. ElGamal算法

(3) 安全性

由于ElGamal密码的安全性建立在 $GF(p)$ 离散对数的困难性上，而目前尚无求解有限域 $GF(p)$ 离散对数的有效算法，所以在 p 足够大时ElGamal密码是安全的。

为了安全， p 应该为150位以上的十进制数，而且 $p-1$ 应有大素因子。

此外，为了安全加密和签名所使用的 r 必须是一次性的：

- ① 如果使用的 r 不是一次性的，时间长了就可能被攻击者获得。又因 y 是公开密钥，攻击者就可以计算出 U ，进而利用Euclid算法求出 U^{-1} 。又因为攻击者可以获得密文 C_2 ，因此可以通过计算 $U^{-1} C_2$ 得到明文 M 。
- ② 另外，假设用同一个 r 加密两个不同的明文 M 和 M' ，相应的密文为 (C_1, C_2) 和 (C_1', C_2') 。因为 $C_2 / C_2' = M / M'$ ，如果攻击者知道 M ，则很容易求出 M' 。

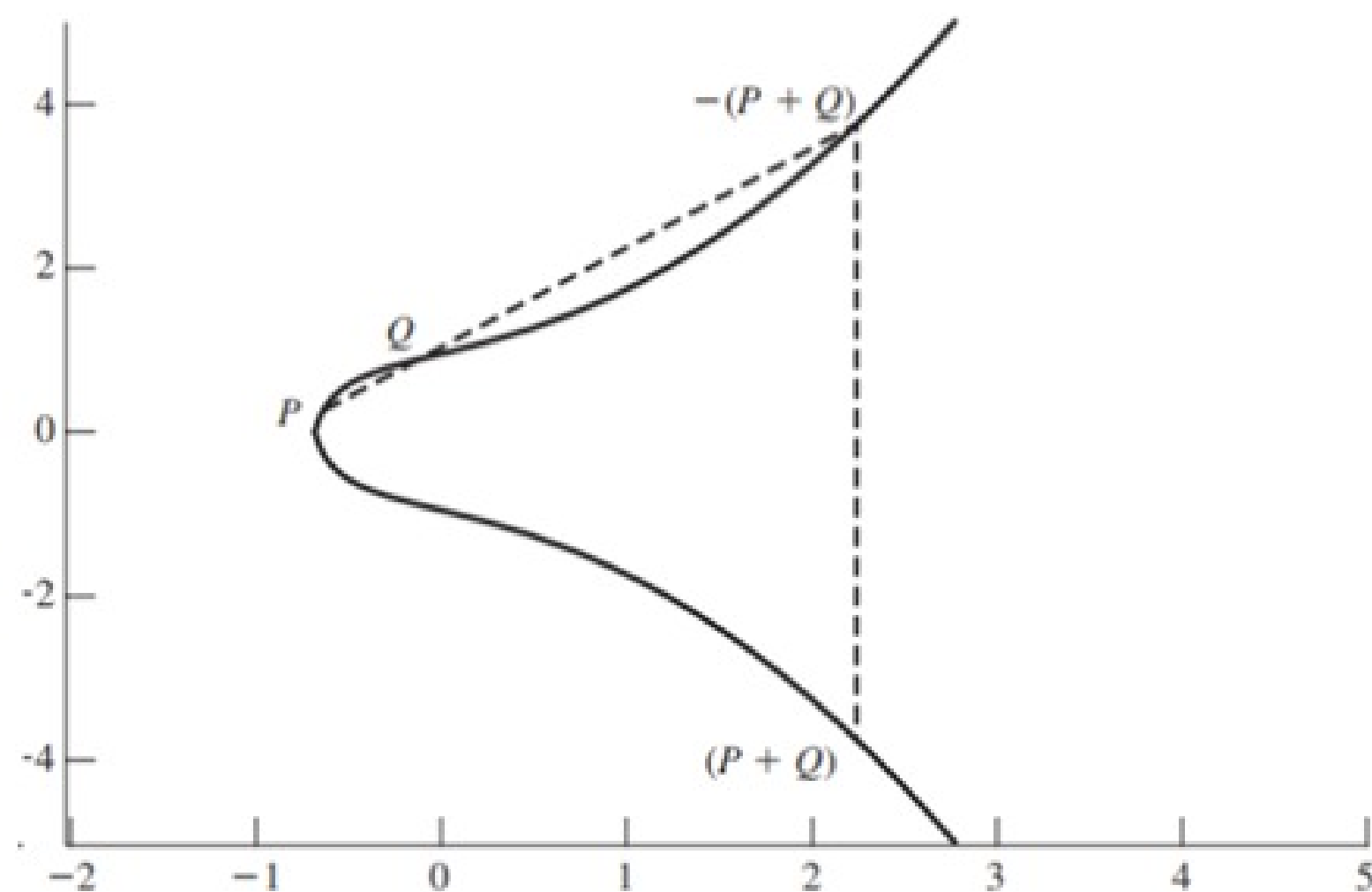
4. 椭圆曲线密码

(1) 椭圆曲线离散对数问题

在椭圆曲线加密（ECC, Elliptic curve discrete）中，利用了某种特殊形式的椭圆曲线，即定义在有限域上的椭圆曲线。其方程如下：

$$y^2 = x^3 + ax + b \pmod{p}$$

其中 p 为一个素数或2的幂（有时也称为椭圆曲线的秩），且 $4a^3 + 27b^2 \neq 0$ 。



4. 椭圆曲线密码

(1) 椭圆曲线离散对数问题

椭圆曲线离散对数问题（ECDLP, Elliptic curve discrete logarithm problem）定义如下：给定素数 p 和椭圆曲线 E ，给定椭圆曲线上两点 P 和 W ，对 $W=kP$ ，求 k 的值。

可以证明，已知 k 和 P 计算 W 比较容易，而由 W 和 P 计算 k 则比较困难，至今没有有效的方法来解决这个问题，这就是椭圆曲线加密算法原理之所在。

□ 注意： kP 是指定义在加法运算符“+”上的 k 个 P 执行运算“+”，类似于 P^k 次方。

□ 类似这样的特性：向一个方向计算容易，但反方向倒推很难的算法被称作单向陷门函数（**Trapdoor Function**）。

□ 椭圆曲线离散对数可以用来构造一个很好的陷门函数。

4. 椭圆曲线密码

(2) 椭圆曲线加密

将ECDLP嵌入到加密系统中的方法有很多种，最简单的一种实现方法描述如下：

- ① Alice首先选择一条椭圆曲线以及该曲线上的一点 G ，然后选取一个保密数字 k ，该数字将作为她的私钥。她的公钥为 G 和 P_A ，其中 $P_A=kG$ ，并将公钥给Bob。
- ② 当Bob要给Alice发送一个消息时，他需要先将明文转换成数字 m ，并在曲线上找出一一点 P_m ，使其 x 坐标值与 y 坐标值之差为 m 。再选择一个随机数 r ，然后将得到的密文 $C=(C_1, C_2)$ 发送给Alice，其中：

$$C_1 = rG, C_2 = P_m + rP_A$$

- ③ Alice收到消息后，通过用自己的私钥与 C_1 相乘，并用第二点减去它，就可以很容易完成解密：

$$C_2 - kC_1 = P_m + rP_A - k(rG) = P_m + r(kG) - k(rG) = P_m$$

4. 椭圆曲线密码

(3) 安全性与性能

- 攻击者得到 C_1 和 C_2 后，因为椭圆曲线离散对数问题，它无法计算计算得到 r 或者 k ，因此是安全的。
- ECC使用较小的密钥就可以提供比RSA更高的安全级别，如160位ECC与1024位RSA有相同的安全强度。

5. 应用示例

公钥基础设施（PKI, Public Key Infrastructure），是一种遵循既定标准的密钥管理平台，它能够为所有网络应用提供加密和数字签名等密码服务及所必需的密钥和证书管理体系，简单来说，PKI就是利用公钥理论和技术建立的提供安全服务的基础设施。

数字证书是指在互联网通讯中标志通讯各方身份信息的一个数字认证，人们可以在网上用它来识别对方的身份。在PKI体系中，建有证书管理机构CA(Certificate Authority)。CA中心的公钥是公开的，因此由CA中心签发的内容均可以验证。

5. 应用示例

密钥的生存周期包括：密钥的产生和登记、密钥分发、密钥更新、密钥撤销、密钥销毁等。在产生密钥后，公钥需要在PKI中登记，并通过CA中心的私钥签名后形成公钥证书。由于CA中心的公钥公开，用户可以方便的对公钥证书进行验证，进而用户可以通过公钥证书来互相交换自己的公钥。进而，PKI作为安全基础设施，能够提供身份认证、数据完整性、数据保密性、数据公正性、不可抵赖性和时间戳六种安全服务。

PKI的应用非常广泛，其为网上金融、网上银行、网上证券、电子商务、电子政务等网络中的数据交换提供了完备的安全服务功能。

OpenSSL库提供了相关的基本功能支撑，下面提供一个数字签名及认证的简单示例。

实验1.2： 在OpenSSL中进行数据签名及验证。

非对称密码设计的主要思想是

- ☐ A 使用公钥来加密，使用私钥来解密
- ☐ B 基于难解问题
- ☐ C 基于离散对数求解困难问题
- ☐ D 加解密操作的交换性

谢 谢

